

Évaluation 1

L'organisation cliente

L'aventure Skiloisir débute en 1998 quand Christophe Lelou décide de se lancer dans la distribution d'articles de sports de montagne avec l'acquisition d'un magasin de 40 m² dans la station des Coches (Savoie). Aujourd'hui, Skiloisir est l'un des leaders français sur son marché avec 45 magasins de sport essentiellement basés en Savoie.

Le réseau informatique de l'ensemble des magasins est géré par un prestataire historique : Sécuinfo73.

L'entreprise Skiloisir a récemment été alertée de la violation de données à caractère personnel lors du traitement des réservations de matériel sur le site Web vitrine des magasins. Elle demande à la société Sécuinfo73 de repérer les éventuelles vulnérabilités du traitement des réservations de matériel et de proposer des solutions adaptées.

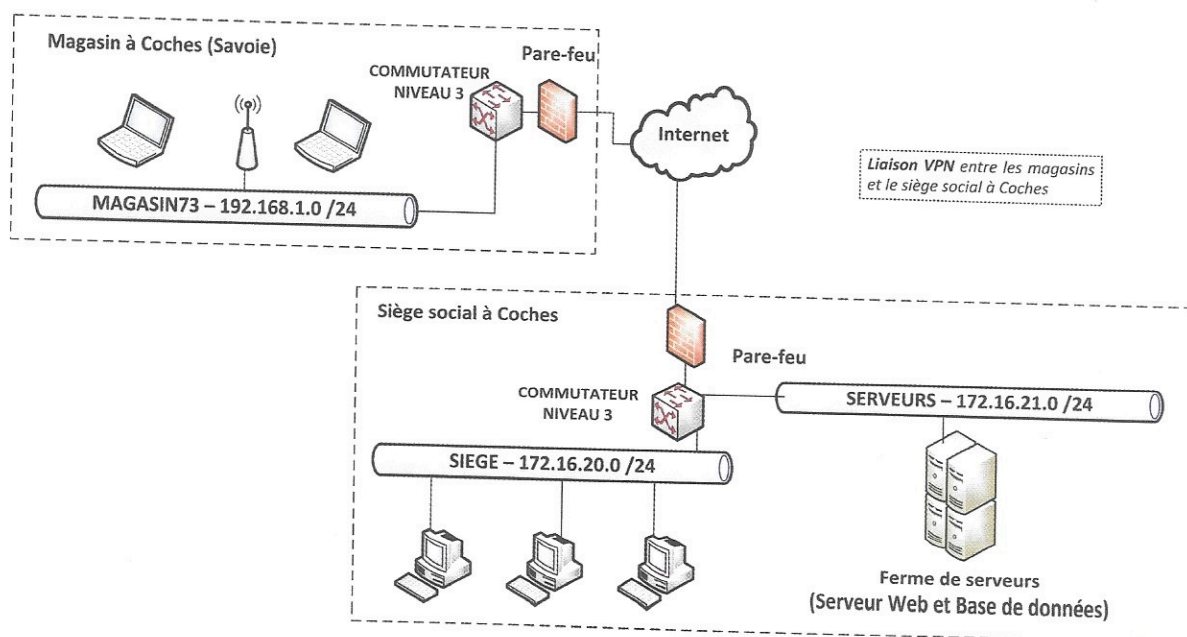


Le prestataire informatique

La société Sécuinfo73, située à Montmélian, est spécialisée dans l'audit et l'accompagnement des entreprises concernant les changements de processus de leur système d'information.

En tant que nouveau salarié(e) de cette société, vous devez prendre en charge l'audit du processus de réservation de matériel via le site Web vitrine de Skiloisir.

Architecture réseau du groupe Skiloisir



Votre mission

Dans un premier temps, votre mission consiste à participer au recensement des vulnérabilités dans le processus de traitement des réservations de matériel. Dans un second temps, vous proposez des solutions adaptées pour assurer la mise en conformité des traitements réalisés sur les données à caractère personnel avec la législation. Vous vous appuyez sur le dossier documentaire mis à votre disposition.

Missions

1 Analyser les risques sur les traitements des données à caractère personnel

Dans cette première mission, vous devez diagnostiquer les vulnérabilités et le niveau de risque sur les données à caractère personnel des clients lors de leurs réservations de matériel via le site Web de l'entreprise. Pour cela, vous disposez d'un entretien avec la responsable du magasin de la station des Coches et de divers documents fournis par la DSI du groupe.

- 1.1. Repérez les vulnérabilités organisationnelles et technologiques sur la protection des données à caractère personnel.
- 1.2. Précisez en quoi le protocole utilisé pour le transfert des données via le formulaire d'inscription du site Web de Skiloisir ne permet pas de répondre à l'ensemble des critères de sécurité.
- 1.3. Commentez le niveau de risque diagnostiqué pour le traitement des réservations de matériel.

2 Mettre en conformité le traitement des réservations de matériel avec la législation

Dans cette deuxième mission, vous devez vérifier la conformité de la protection des données à caractère personnel avec la législation, notamment le traitement des inscriptions des nouveaux clients et la consultation de la base de données depuis l'ordinateur d'un magasin.

- 2.1. Identifiez les éléments non conformes au RGPD (règlement général sur la protection des données) lors de l'inscription des nouveaux clients et de la consultation de la base de données depuis l'ordinateur d'un magasin.
- 2.2. Rédigez une note dans laquelle vous proposez une liste des solutions techniques et organisationnelles devant permettre une mise en conformité de la protection des données à caractère personnel.

Dossier documentaire

Document 1

Entretien avec la responsable du magasin de la station des Coches

M. Legrand : Bonjour M^{me} Ajouaou, je suis M. Legrand, salarié de la société Sécuinfo73, et comme convenu avec la direction de votre groupe, j'aimerais vous interroger sur les traitements réalisés lors de la réservation de matériel de ski. Pouvez-vous me résumer le processus de réservation du matériel pour un client depuis le site Web du groupe Skiloisir ?

M^{me} Ajouaou : Bonjour M. Legrand. Un nouveau client doit, dans un premier temps, s'inscrire sur le site Web pour bénéficier d'un identifiant et d'un mot de passe en précisant dans le formulaire d'inscription les données suivantes : genre (homme ou femme), nom, prénom, adresse complète et numéro de téléphone. Les données sont conservées pendant 10 ans dans un serveur spécifique hébergé dans nos locaux. Dans un deuxième temps, le client s'identifie sur notre site Web et choisit le magasin le plus proche de sa situation géographique. Sur la page dédiée au magasin de proximité, le client va pouvoir visualiser la disponibilité du matériel et le réserver.

M. Legrand : Je suppose qu'après la réservation, vous avez la possibilité de voir les modifications sur la base de données de votre boutique. Pouvez-vous me préciser votre démarche en magasin ?

M^{me} Ajouaou : Tout à fait, je me connecte chaque matin à mon ordinateur (Windows 10) avec mon identifiant et mon mot de passe, puis je consulte tous les jours les réservations enregistrées dans notre base de données commune au groupe afin de préparer le matériel.



Document 2

Site Web vitrine du groupe Skiloisir



Document 3

Note interne concernant la sécurisation des échanges sur un site Web

Le protocole HTTP (*Hypertext Transfer Protocol*) correspond à un ensemble de règles utilisé par les navigateurs pour déterminer comment lire et transférer des données sur le Web. Lorsqu'une URL contient « http », le navigateur sait qu'il doit suivre ce protocole pour charger une page Web.

Le protocole HTTPS est identique au protocole HTTP, sauf qu'il indique au navigateur de chiffrer les données échangées sur une page Web. Le chiffrement permet de masquer les données et de réduire les risques d'exposition ou de manipulation de vos informations. Le chiffrement est particulièrement

utile lorsqu'un site Web comporte des données sensibles, telles que vos informations personnelles ou financières.

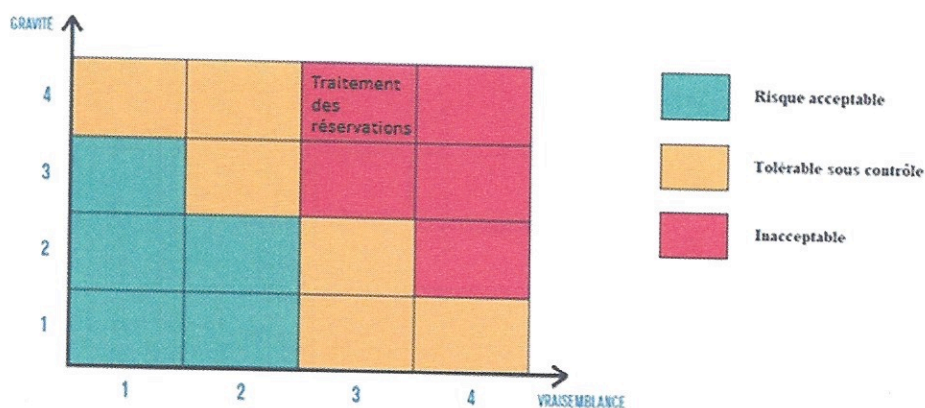
Pour utiliser le protocole HTTPS avec votre nom de domaine, vous devez disposer d'un certificat SSL ou TLS installé sur votre site Web. Il se peut que votre hôte Web (fournisseur d'hébergement Web) propose la sécurité HTTPS. Sinon, vous pouvez demander à obtenir un certificat SSL/TLS auprès d'une autorité de certification et l'installer vous-même.

Le service DSI du groupe Skiloisir

Document 4

Cartographie des risques sur le traitement des réservations de matériel de ski

La cartographie présentée est le résultat de l'utilisation de la méthode EBIOS Risk Manager (expression des besoins et identification des objectifs de sécurité), développée par l'ANSSI.



Document 5

Extrait du guide de l'ANSSI sur les recommandations relatives à l'authentification multifacteur et aux mots de passe

L'authentification multifacteur découle de la nécessité de renforcer la sécurité apportée par l'utilisation d'un unique facteur d'authentification, particulièrement lorsqu'il s'agit d'un mot de passe utilisé seul. Ainsi, même si ce dernier est compromis, un facteur supplémentaire d'un type différent est requis afin de s'authentifier.

Un facteur d'authentification est donc un facteur lié à une personne, relevant de diverses catégories :

- facteur de connaissance : « ce que je sais », il s'agit d'une connaissance devant être mémorisée, telle qu'une phrase de passe, un mot de passe, un code, etc. ;

- facteur de possession : « ce que je possède », il s'agit d'un élément secret non mémorisable contenu dans un objet physique qui protège idéalement cet élément de toute extraction, tel qu'une carte à puce, un *token*, un téléphone, etc. ;

- facteur inhérent : « ce que je suis », il s'agit d'une caractéristique physique intrinsèquement liée à une personne et indissociable de la personne elle-même, telle qu'une caractéristique biologique (ADN), morphologique (empreinte digitale, empreinte rétinienne) ou comportementale (voix, frappe au clavier).

ANSSI, *Recommandations relatives à l'authentification multifacteur et aux mots de passe*,
8 octobre 2021, www.ssi.gouv.fr

Document 6

Clés de sécurité FIDO

Les clés de sécurité FIDO sont de petits dispositifs qui permettent de sécuriser la connexion aux sites et aux applications Web. Elles sont la solution au problème de la faiblesse des mots de passe, de l'escroquerie par hameçonnage, du piratage et des enregistreurs de frappe. [De nombreux systèmes d'exploitation utilisent déjà FIDO2.]

FIDO est un ensemble de normes d'authentification à double facteur et multifacteur mises en place par l'Alliance FIDO. FIDO est l'acronyme de *Fast IDentity Online* [(identification rapide en ligne)] et cette authentification utilise une cryptographie à clé publique pour fournir une authentification robuste afin de protéger les utilisateurs en ligne.

fr.microcosm.com



© DR